Instituto Tecnológico y de Estudios Superiores de Monterrey
Escuela de Ingeniería y Ciencias, Campus Monterrey
Integración de seguridad informática en redes y sistemas de software (Gpo 403)

Reto: Sistema completo, documentación y presentación final

Equipo NeuralHub · Socio formador: Fundación Estancias Infantiles Sonrisas de Cristal

Estudiantes
Santiago Hernández Senosiain A01787550
Gilberto Olavarrieta Sánchez A01286889
Franco Salazar Guerrero A01178655
Gerardo Islas Gómez A01739896

Profesores
Juan David Guarnizo Hernández
Rolando Evelio Pérez Versón
Aída Judith Gándara Tovar

22 de octubre de 2026

Agenda (15 min)

Problema, alcance y requerimientos (2 min)

Demo en vivo (5 min)

Pruebas y matriz (2 min)

Seguridad (2 min)

Capacidad diferenciadora (1 min)

Documentación, implantación y dilemas éticos (3 min)

- Bitácora diaria en papel
- Fotos de menores en teléfonos personales, enviadas por WhatsApp
- Costo aproximado: $2,900 al mes por estancia

Alcance y requerimientos

- Una sola plataforma, 4 roles: Fundación, Dirección, Educadora y Familiar
- App Android con backend propio
- 21 RF: 14 validados por el socio formador y 7 propuestos
- 36 historias de usuario en 8 épicas
- **20 de 21 RF cumplidos**; RF-11 (modo offline) quedó fuera de alcance

Demo en vivo

5 min

1. APK *release* instalada en un teléfono
2. Educadora: registra la llegada, la bitácora y una foto
3. Familia (otra cuenta, mismo backend): ve el día de su hijo
4. Familia y educadora: intercambian un mensaje
5. Fundación: desbloquea una cuenta bloqueada

Respaldo: video grabado de la misma demo, por si falla la red.

- Backend: **97 pruebas** aprobadas en H2 y en PostgreSQL 17 real
- App: 7 *unit tests*
- Niveles:
  - *unit*
  - integración de API
  - seguridad
  - DAST (OWASP ZAP)
  - sistema en dispositivo

Matriz de pruebas (extracto)

RF	Requisito	Evidencia	Estado
RF-03	Entrada y salida	`RF03AsistenciaTest` (4)	Cumplido
RF-07	Cada familia ve solo a sus hijos	`RF07FamiliaSoloSusHijosTest` (4)	Cumplido
RF-09	Foto visible solo a los etiquetados	`RF09FotosVisiblesTest` (4)	Cumplido
RF-10	Borrar una foto para todos	`RF10EliminarFotoTest` (4)	Cumplido
RF-14	Registro de quién hizo qué	`RF14RegistroActividadTest` (4)	Cumplido
RF-16	Autorización de imagen	Validación en `POST /fotos` y prueba en dispositivo	Cumplido
RF-18	Baja y eliminación	`ARCOEliminacionTest` (3)	Cumplido
RF-11	Funciona sin internet	No se implementó	Pendiente

- Contraseñas con PBKDF2 (210k iteraciones)
- Tokens opacos, guardados como SHA-256
- Android Keystore con AES-GCM
- Revisión de BOLA en cada ruta
- SQL parametrizado
- *Rate limit*; 3 IPs distintas bloquean la cuenta 3 días; solo un administrador la desbloquea
- Archivos: *magic bytes* y EXIF eliminado
- La hora la pone el servidor
- Cabeceras de seguridad
- Docker endurecido
- Cloudflare Tunnel
- OWASP ZAP autenticado: 0 alertas altas, medias o bajas (PASS 120)

Referencia: OWASP Top 10 2025 y OWASP API Security Top 10 2023

Fotos con reglas

1 min

- Dos permisos de imagen separados: actividades internas y redes sociales
- Cada familia ve solo las fotos de su hijo
- Cualquiera de esas familias puede borrar la foto para todos
- Cada captura y cada consulta quedan registradas

- Manual de usuario, manual de instalación y arquitectura
- APK firmada y backend en Docker
- Sin datos previos que migrar: la bitácora en papel se reemplaza por captura inicial desde la app
- *Rollback* con `pg_dump`

Aviso de privacidad

- LFPDPPP (DOF 20-03-2025): arts. 8, 15, 21–31 y 36
- LGDNNA: art. 76

Dilemas éticos

Dilema	Cómo lo resolvimos
Compartir fotos vs. privacidad del menor	RF-16: permisos de imagen; RF-07 y RF-10: cada familia ve solo a su hijo y puede borrar la foto
Trazabilidad vs. privacidad del registro	RF-14: solo la Dirección lee el registro; los mensajes no se copian a él
Eliminación vs. auditoría	Borrar un expediente elimina sus registros y la cuenta de la familia

Gracias

¿Preguntas?